



ВШЭ

Программная
инженерия

Москва
2026

Лекция № 12.

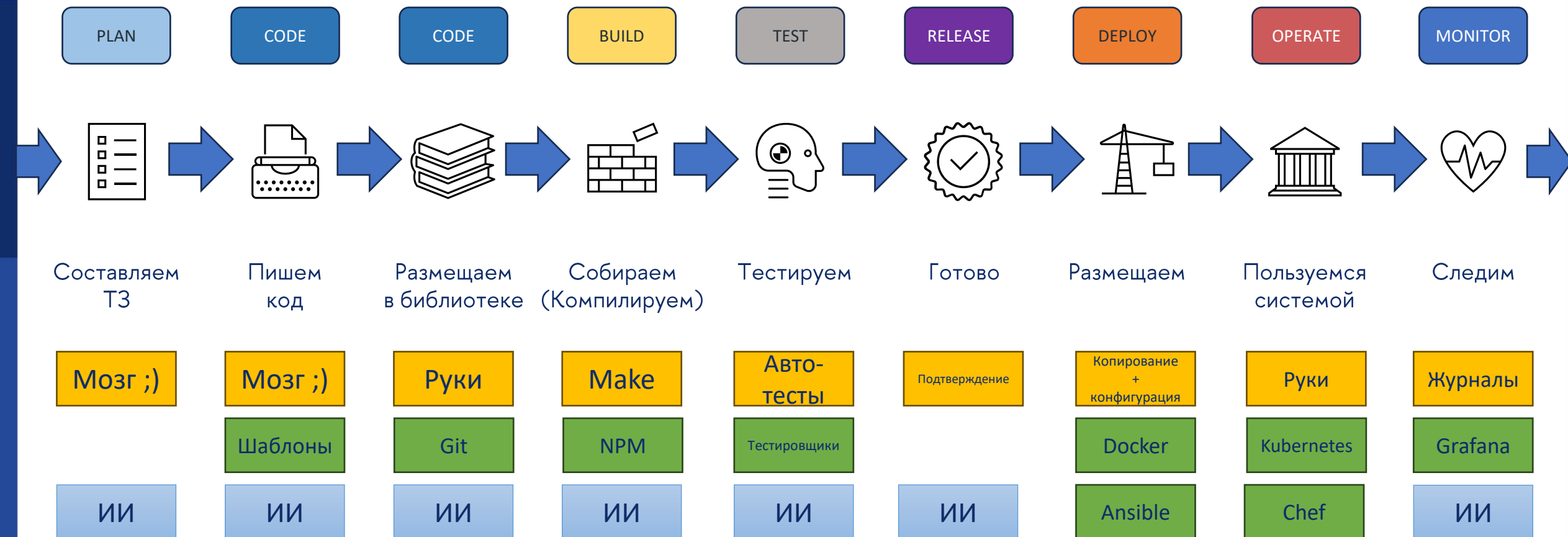
Безопасная разработка ПО.

DevSecOps

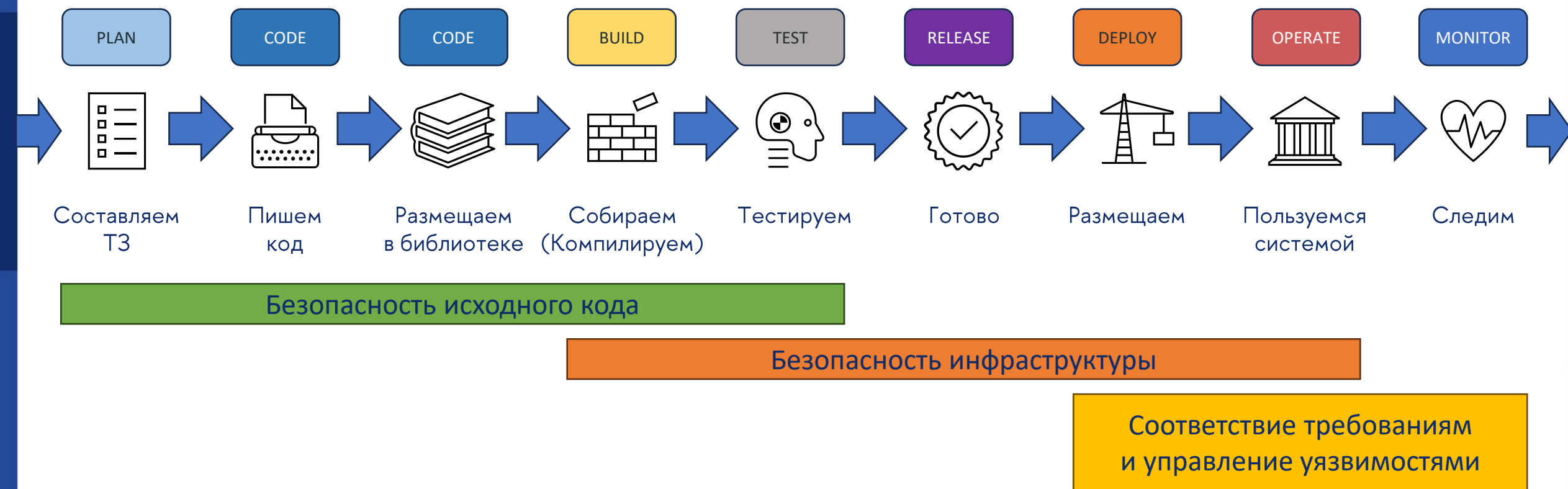
Основы кибербезопасности
Белявский Д.А.



Подробный процесс разработки ПО



Безопасный процесс разработки ПО



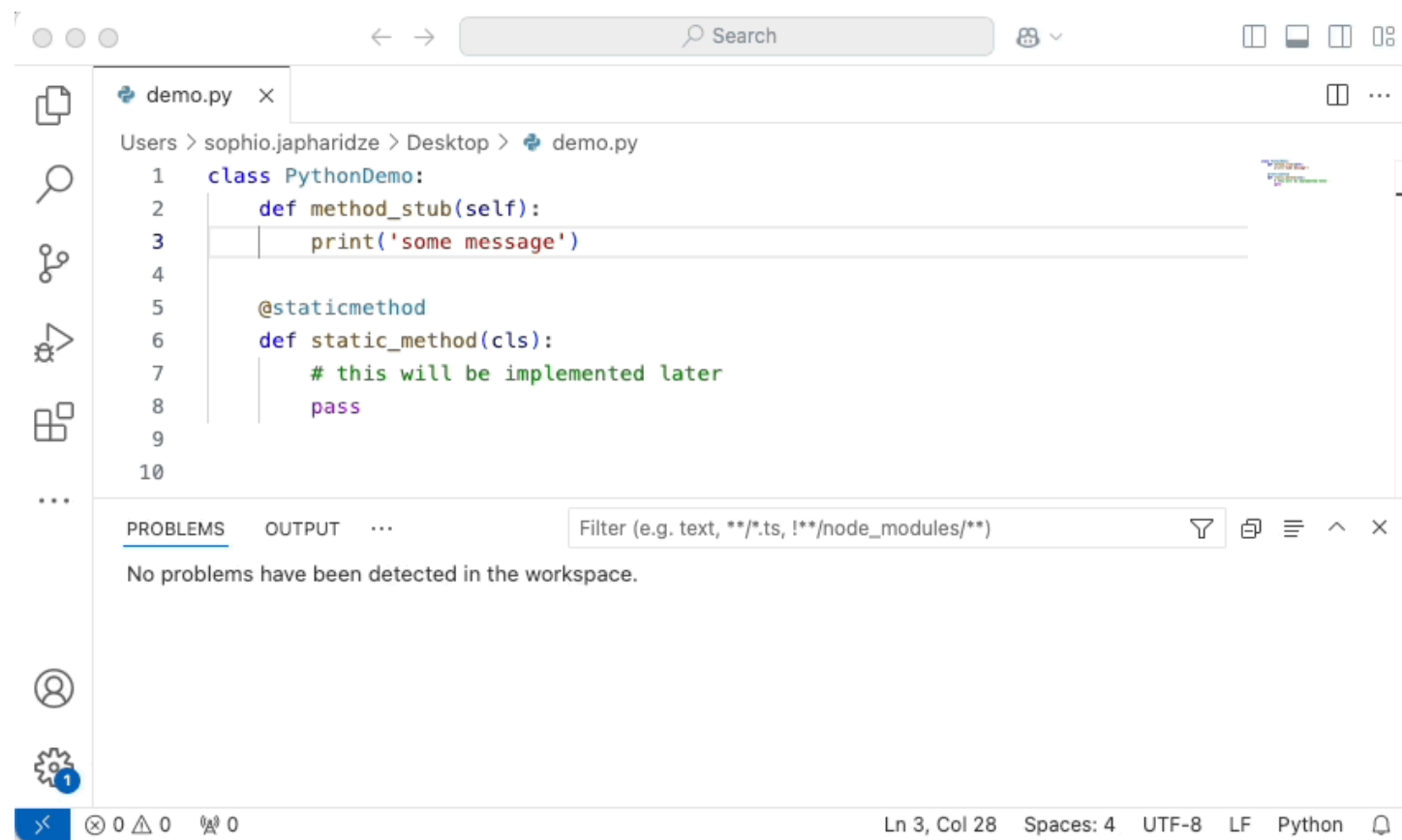


Плагин для практически любой IDE, который позволяет в режиме реального времени проверять код на уязвимости и ошибки. Выполняет статический анализ кода (линтер)



<https://github.com/SonarSource/sonarlint-vscode>

SonarQube



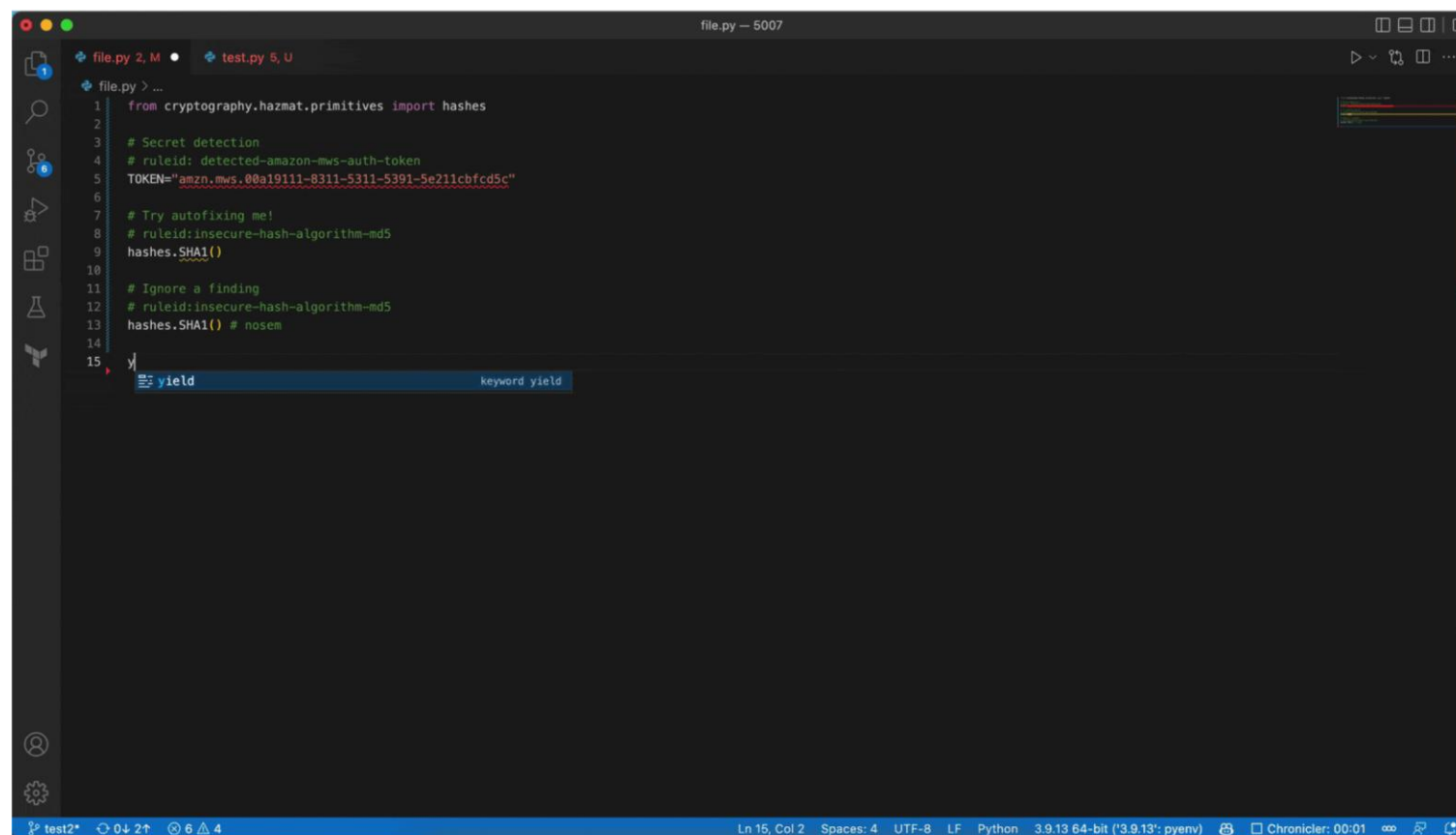
Semgrep



Плагин для VS Code, Emacs и IntelliJ Idea, а также «движок» для других - DejectDojo, GitLab SAST и др. Также контролирует pre-commit хук, выполняя проверку перед commit'ом в git.



<https://semgrep.dev/>



```
1 from cryptography.hazmat.primitives import hashes
2
3 # Secret detection
4 # ruleid: detected-amazon-mws-auth-token
5 TOKEN="amzn.mws.00a19111-8311-5311-5391-5e211cbfcd5c"
6
7 # Try autofixing me!
8 # ruleid:insecure-hash-algorithm-md5
9 hashes.SHA1()
10
11 # Ignore a finding
12 # ruleid:insecure-hash-algorithm-md5
13 hashes.SHA1() # nosem
14
15 yield
```

PT Application Inspector

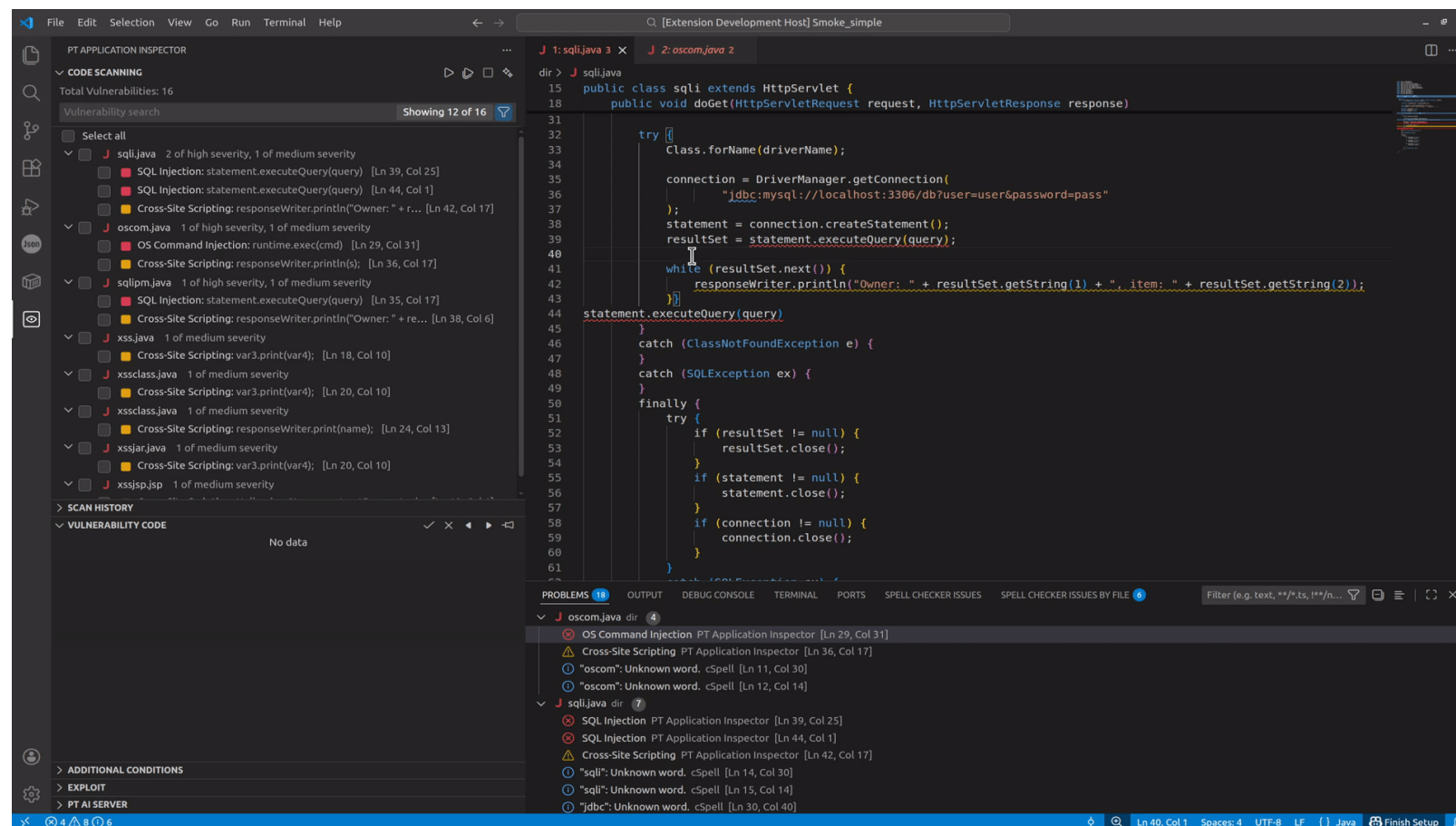


PT Application Inspector

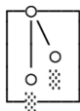
От компании Positive Technologies
Плагин для VS Code и IntelliJ Idea.
Находит уязвимости, ошибки в
конфигурациях



<https://github.com/POSIddev-community/AI.Plugin.VSCode>



Gitleaks



Gitleaks

Инструмент для поиска секретов в исходном коде с классификацией и возможностью настройки на собственные шаблоны конфиденциальных данных.



<https://github.com/gitleaks/gitleaks>

Рекомендуется применять на стадии pre-commit.

Позволяет обнаруживать в коде:

Пароли

Токены

Ключи API

Ключи OAuth (например, от Claude Code)

И любые другие данные по шаблонам

Trivy & Pre-commit



Инструмент для сканирования контейнеров, файловых систем, репозиториях (git), образов виртуальных машин на уязвимости (CVE) и некорректные конфигурации (misconfiguration)



<https://github.com/aquasecurity/trivy>



pre-commit

Возможность использования хука **pre-commit** при работе с системой контроля версий Git, с возможностью написания собственной логики хуков.



<https://github.com/pre-commit/pre-commit>

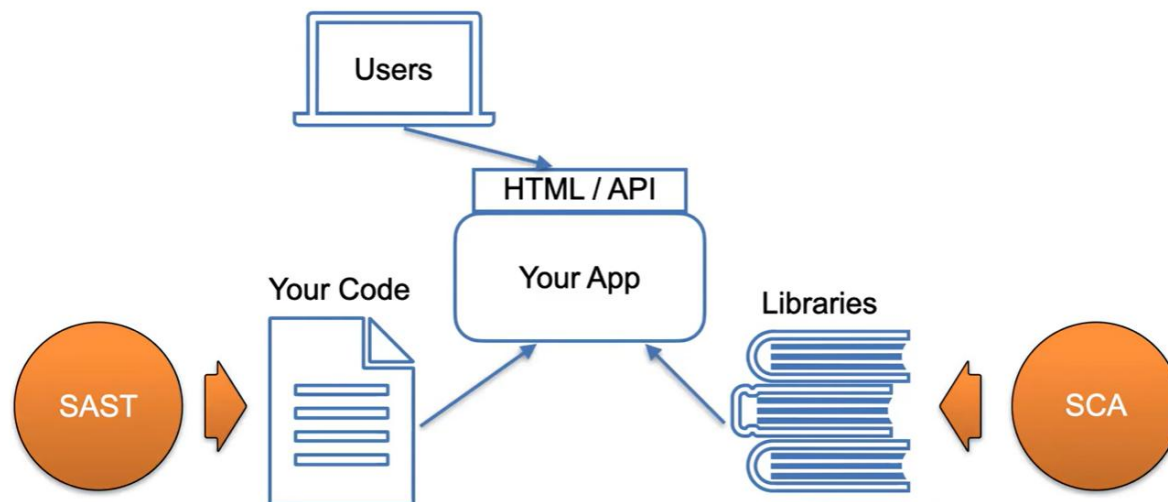
Zed Attack Proxy (ZAP)



Сканер уязвимостей в веб-приложениях, включая SAST и SCA. Хорошо автоматизируемый и расширяемый (большая библиотека расширений)



<https://github.com/zaproxy/zaproxy>



Также есть функционал динамического тестирования (DAST), что позволяет применять ZAP в разных задачах.

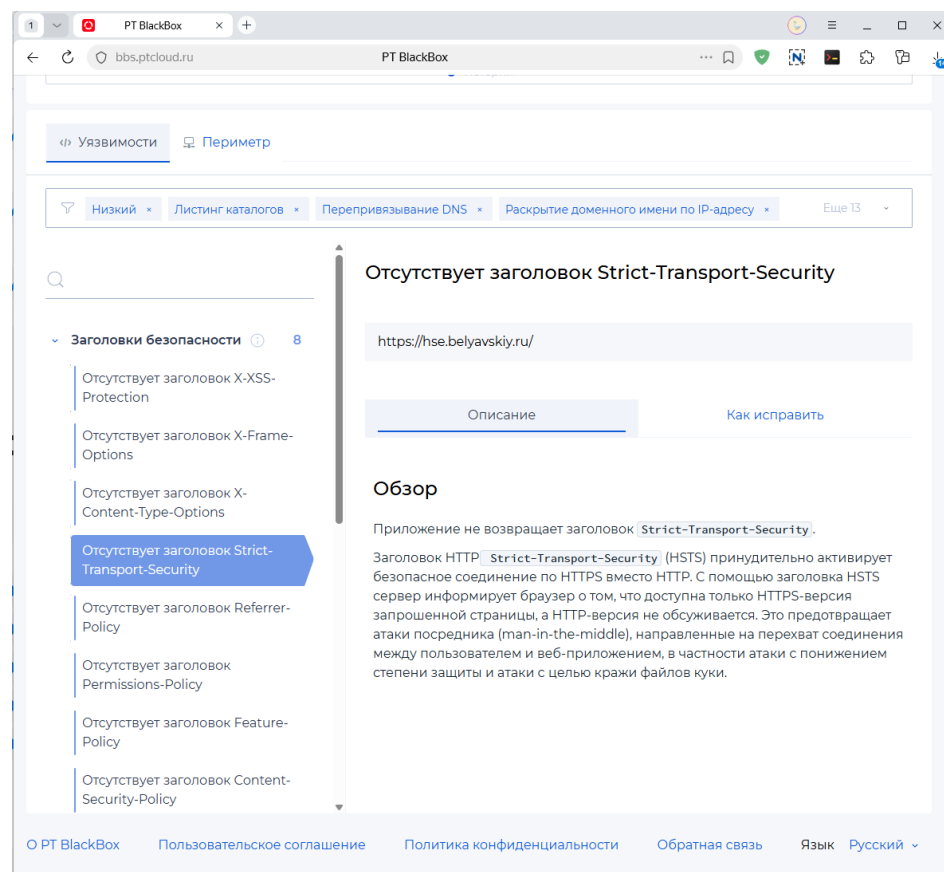
PT Blackbox



От компании Positive Technologies
Онлайн-система для сканирования
приложений на уязвимости (DAST)



<https://bbs.ptcloud.ru/>



Отчет о сканировании
hse.belyavskiy.ru



<https://bbs.ptcloud.ru/shared/FsvJzaR>

PT Blackbox - демо

 **pt blackbox**

Отчет о сканировании
hse.belyavskiy.ru



<https://bbs.ptcloud.ru/shared/FsvJzaR>

Демо

BlackDuck Seeker Interactive



Инструмент для IAST
(интерактивного тестирования).



<https://www.blackduck.com/interactive-application-security-testing.html>

IAST = SAST + DAST

Динамическое сканирование приложений с использованием доступа к исходному коду позволяет повысить качество исследования на уязвимости.

PortSwigger Burp Suite



Инструмент для исследования приложений на уязвимости в режимах SAST, DAST и OAST (Out-of-band)



<https://portswigger.net/>

Функционал

Сканирование приложений на уязвимости

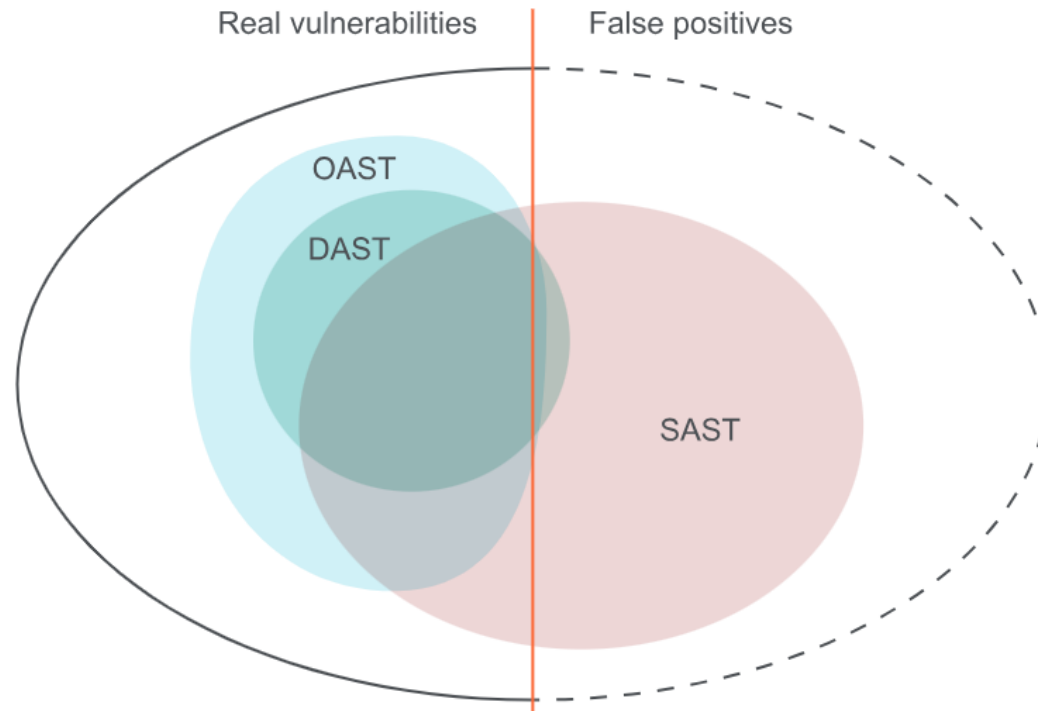
Проверка корректности JSON, YAML, API

Интеграция с любым CI/CD инструментом

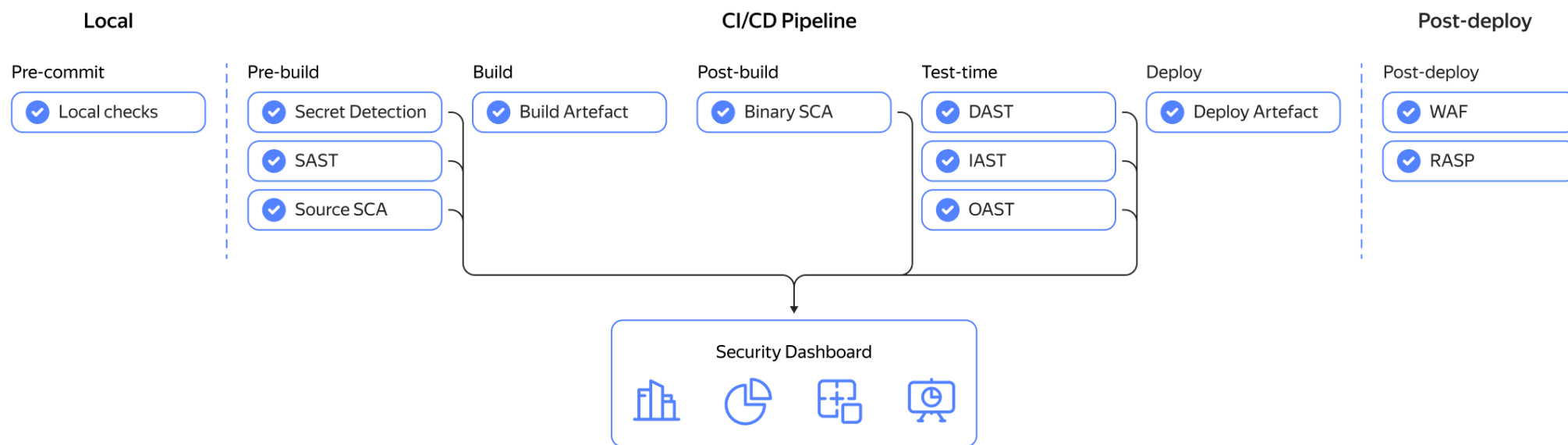
Подробные отчеты с рекомендациями по устранению обнаруженных проблем

Проверка на соответствие стандартам (PCI DSS, OWASP TOP 10)

SAST, DAST, (IAST), OAST...



DevSecOps – мнение Яндекса





Стандарты по безопасной разработке ПО

ГОСТ Р 56939-2024

НАЦИОНАЛЬНЫЙ СТАНДАРТ РОССИЙСКОЙ ФЕДЕРАЦИИ

Защита информации

РАЗРАБОТКА БЕЗОПАСНОГО ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ

Общие требования

Information protection. Secure software development. General requirements

Предотвращение появления, выявление и устранение недостатков, в том числе уязвимостей, в ПО, и содержит общие требования, предъявляемые к разработчикам и производителям ПО

обществом "Научно-производственное объединение "Эшелон" (АО НПО "Эшелон")

2 ВНЕСЕН Техническим комитетом по стандартизации ТК 362 "Защита информации"

3 УТВЕРЖДЕН И ВВЕДЕН В ДЕЙСТВИЕ Приказом Федерального агентства по техническому регулированию и метрологии от 24 октября 2024 г. № 1504-ст

ГОСТ Р 56939-2024

ГОСТ Р 58412-2019

НАЦИОНАЛЬНЫЙ СТАНДАРТ РОССИЙСКОЙ ФЕДЕРАЦИИ

Защита информации

РАЗРАБОТКА БЕЗОПАСНОГО ПРОГРАММНОГО ОБЕСПЕЧЕНИЯ

Угрозы безопасности информации при разработке программного обеспечения

Information protection. Secure software development. Software development life cycle threats

Содержит систематизированный перечень угроз безопасности информации, которые могут возникать при разработке программного обеспечения.

ГОСТ Р 58412-2019

ГОСТ Р 56939-2024. Общие требования

В стандарте
определены
требования к
ПРОЦЕССАМ
безопасной
разработки ПО.



<https://normativ.kontur.ru/document?moduleId=9&documentId=500102>

Планирование (5.1)

Обучение (5.2)

Требования безопасности к ПО (5.3)

Управление конфигурацией ПО (5.4)

Управление недостатками и изменениями (5.5)

Разработка архитектуры ПО (5.6)

Моделирование угроз (5.7)

Правила кодирования (5.8)

Экспертиза исходного кода (5.9)

Статический анализ кода (5.10)

Динамический анализ кода (5.11)

Безопасная система сборки ПО (5.12)

Обеспечение безопасности среды сборки (5.13)

Доступ и контроль целостности исходного кода (5.14)

Безопасность секретов (5.15)

Композиционный анализ (5.16)

Проверка зависимостей (5.17)

Функциональное тестирование (5.18)

Нефункциональное тестирование (5.19)

Выпуск версии готового ПО (5.20)

Безопасная поставка пользователям (5.21)

Обеспечение поддержки (5.22)

Реагирование на уязвимости (5.23)

Поиск уязвимостей (5.24)

Вывод из эксплуатации (5.25)

ГОСТ Р 58412-2019. Угрозы безопасности информации

В стандарте
приведены
угрозы, которые
обязательно
нужно учитывать
при разработке
ПО



<https://docs.cntd.ru/document/1200164529>

Угрозы при выполнении анализа требований к ПО (5.1)

Угрозы при выполнении проектирования архитектуры программы (5.2)

Угрозы при выполнении конструирования и комплексирования ПО (5.3)

Угрозы при выполнении квалификационного тестирования ПО (5.4)

Угрозы при выполнении инсталляции программы и поддержки приемки ПО (5.5)

Угрозы при решении проблем в ПО в процессе эксплуатации (5.6)

Угрозы в процессе менеджмента документацией и конфигурацией программы (5.7)

Угрозы в процессе менеджмента инфраструктурой среды разработки ПО (5.8)

Угрозы в процессе менеджмента людскими ресурсами (5.9)

Что будет на семинаре № 12?

- Продолжаем лабораторные работы (уже №3, будут и другие)
- Поиск уязвимостей. Изучение веб-сервисов.
- Продолжение разбора домашнего задания – задачи пополняются (уже готовы №3 и №4).



